F-01

# 哨望总体架构

| | |
|---|---|
| **接入层** | Web / MCP 7 工具 / OpenAPI<br>CLI / Agent Plugins |
| **服务层** | intel-core　GraphRAG　鉴权与结果裁剪 |
| **智能体编排层** | Orchestrator + 8 个角色　LangGraph |
| **知识层** | PostgreSQL + pgvector　Neo4j　OpenSearch<br>MinIO　Redis Streams 或 NATS JetStream |
| **采集层** | Connector × N　自有仓库 webhook |
| **数据源层** | 9 类来源　三级可信度　分级轮询 |

**时效可观测**

**可信与裁决**

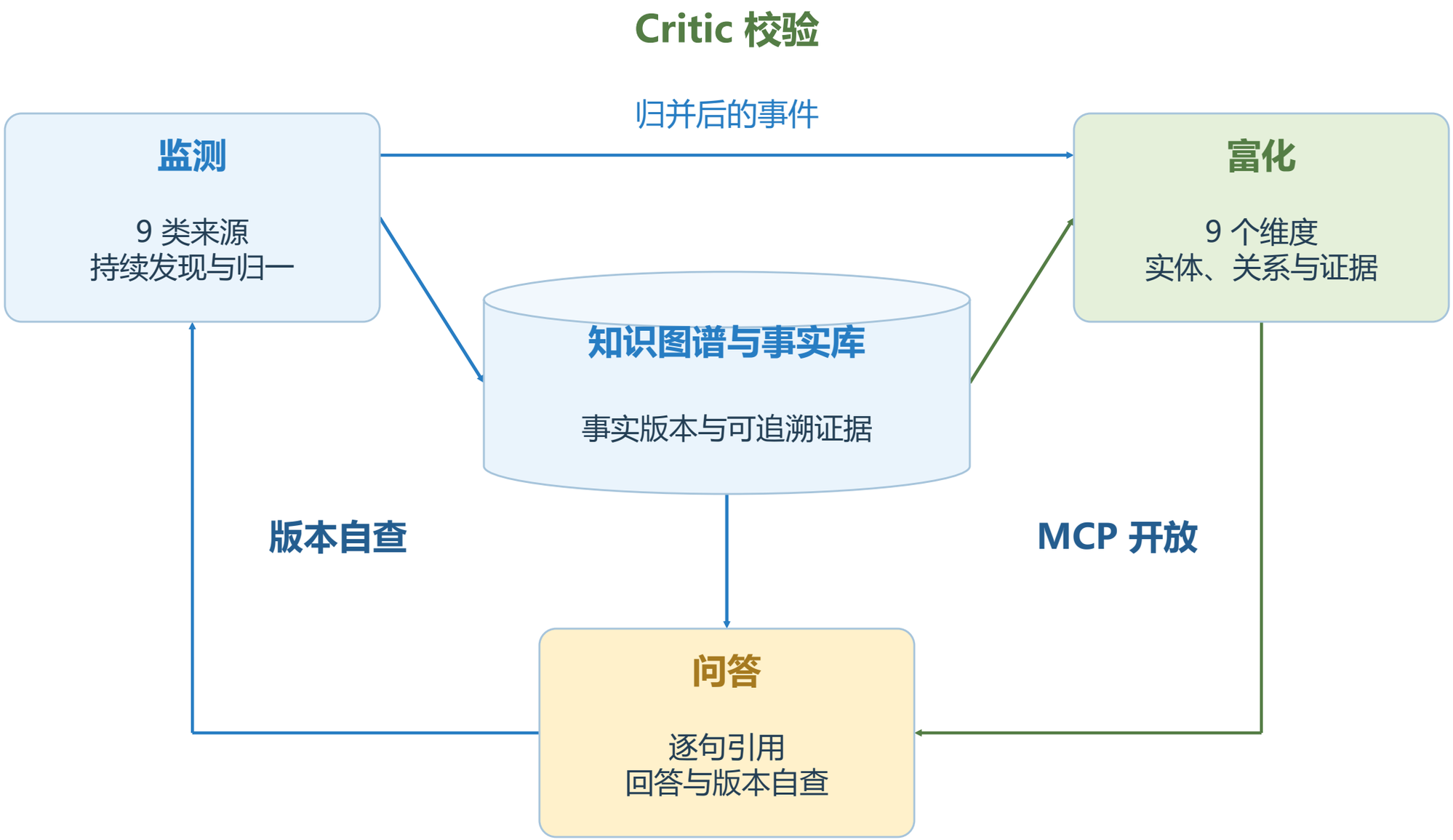
**合规边界**

**开放生态**

PostgreSQL 是事实源；outbox 同步图库与全文索引

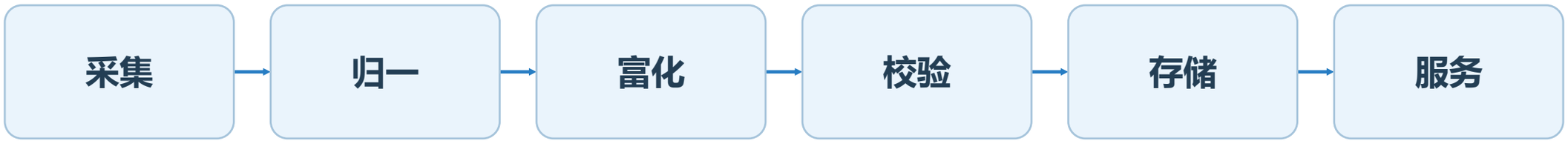
F-02

# 监测—富化—问答闭环




时效可观测贯穿发现、富化、校验与服务

# F-03 端到端数据流与阶段时间戳







采集时延

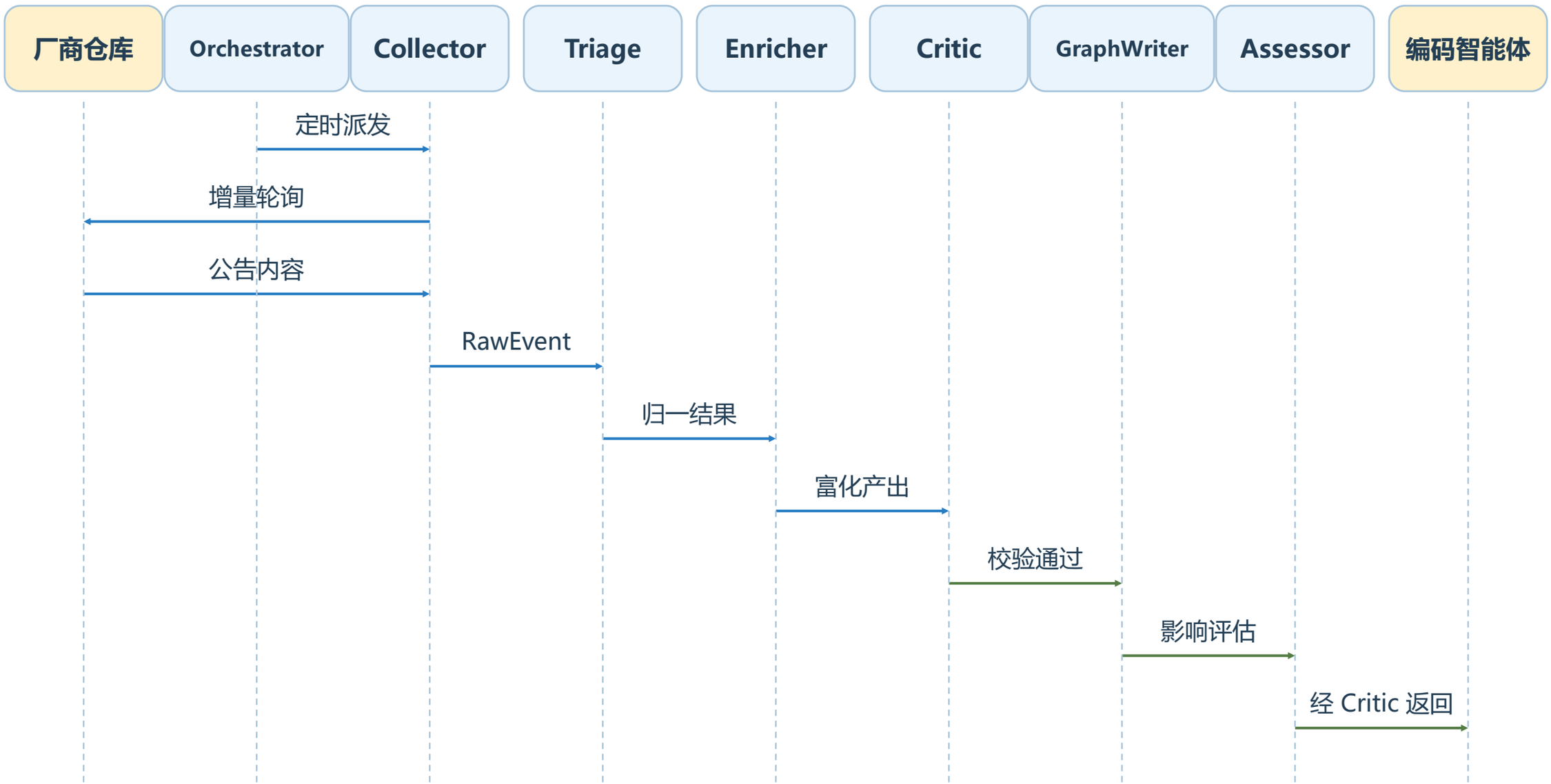
处理时延

**端到端时延目标值 ≤6 h（待测）**

漏洞类首次发现纳入统计；日更源单列；DEMO 不计

F-04

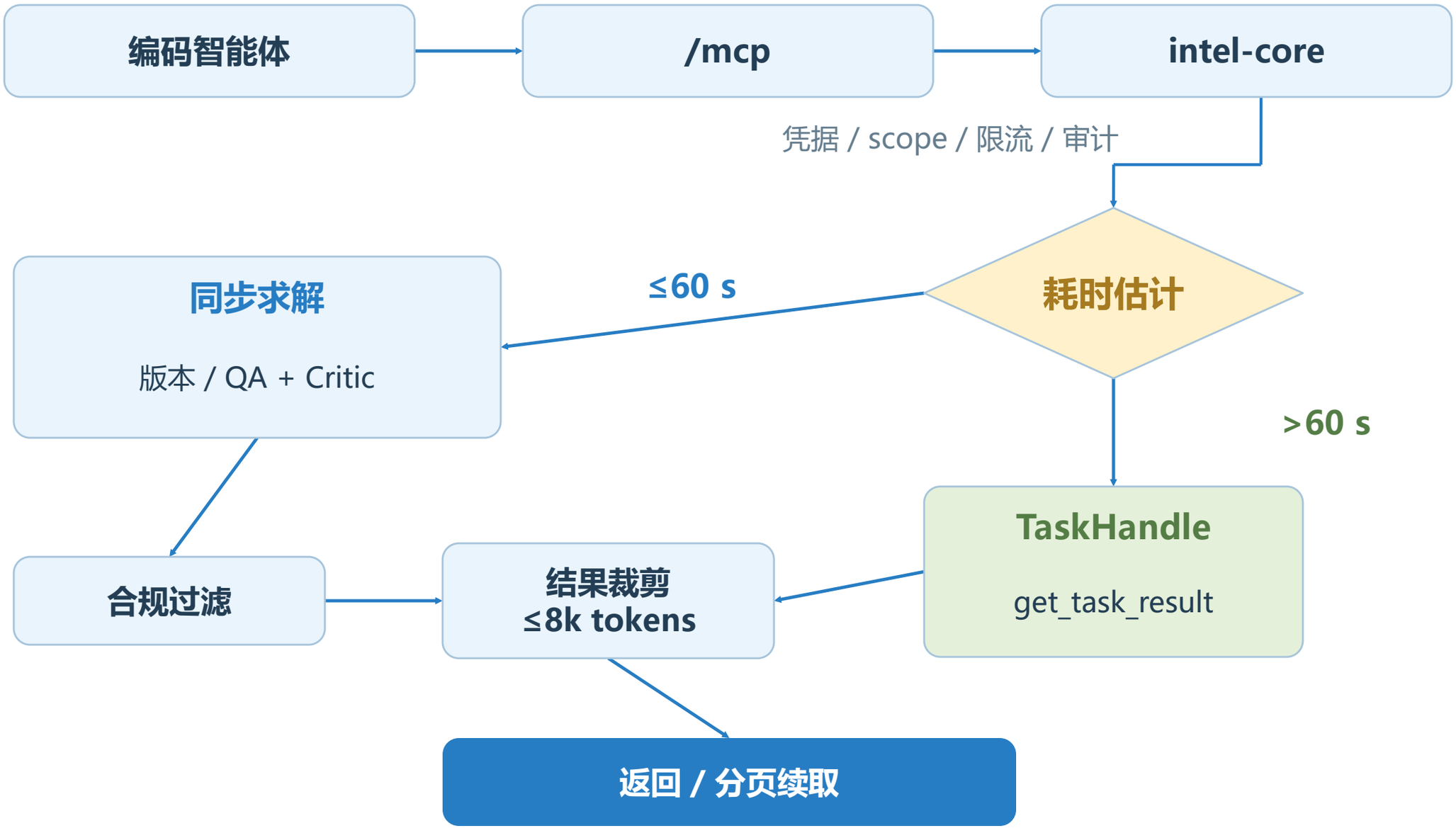
# 一条新公告从发布到可问答的时序




演示注入 / 自有仓库 webhook 验签后触发立即 poll；DEMO 单列

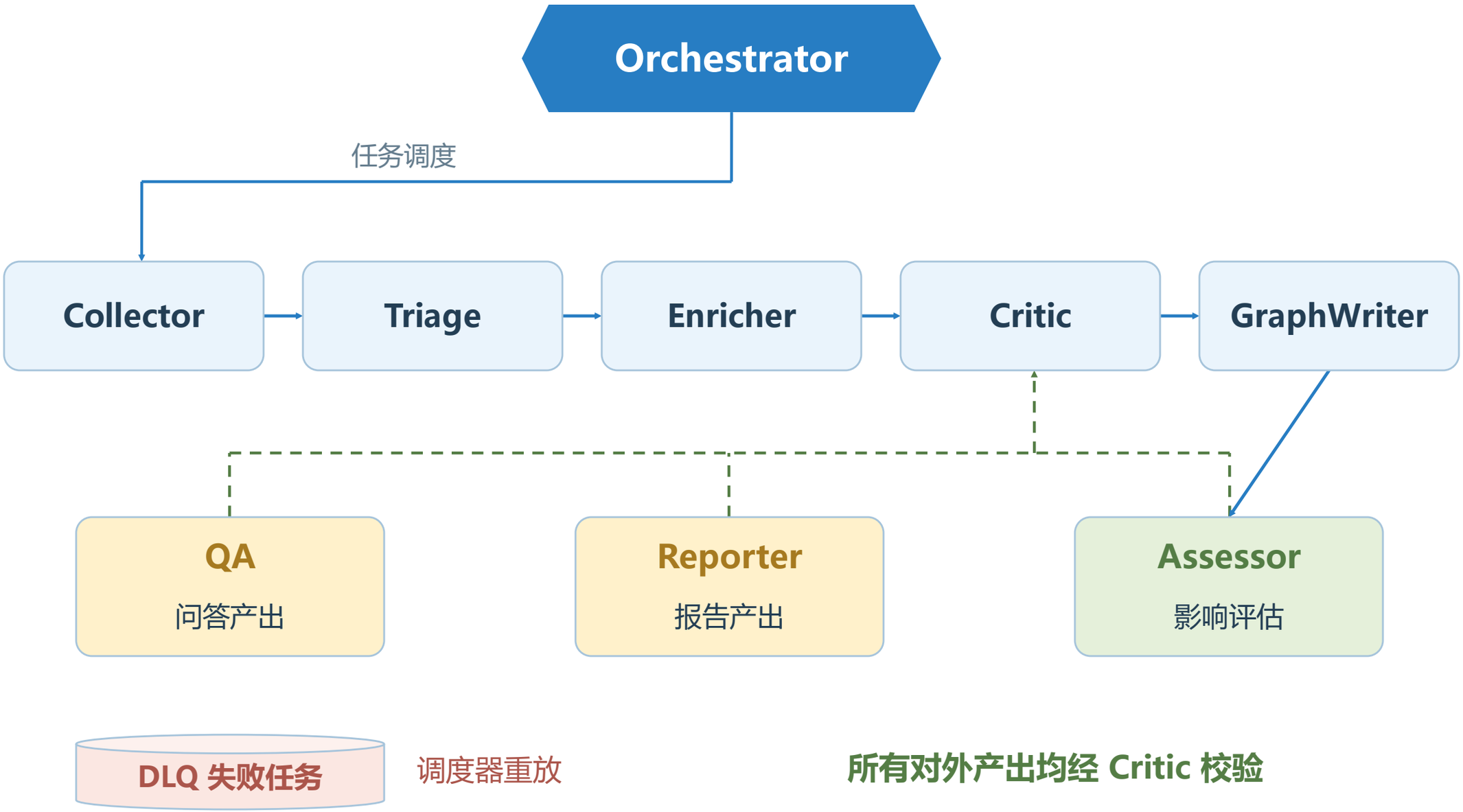
F-05

# 查询请求的处理路径



F-06

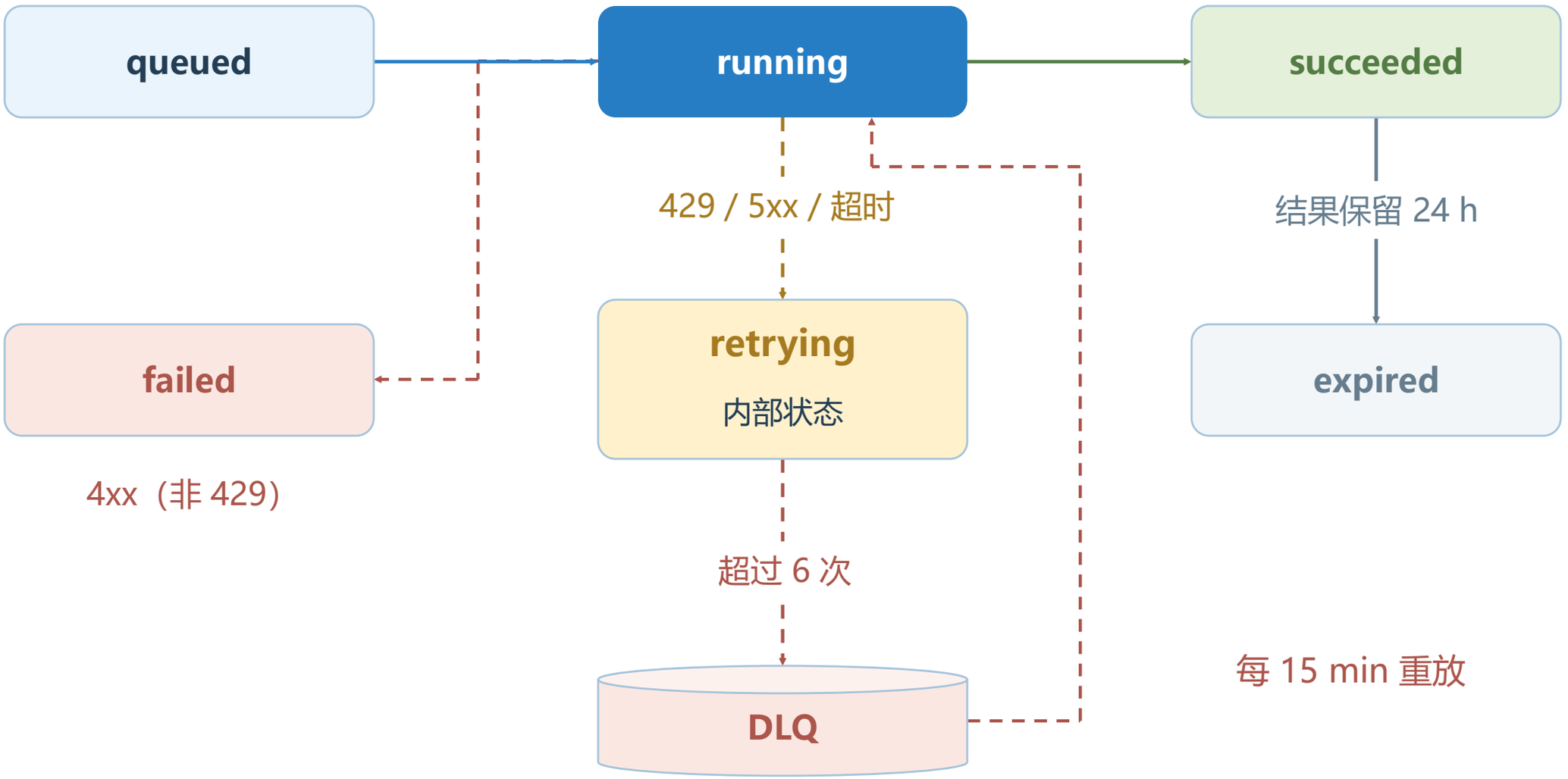
# 九个智能体的协作关系




9 个角色通过数据与任务状态交接

F-07

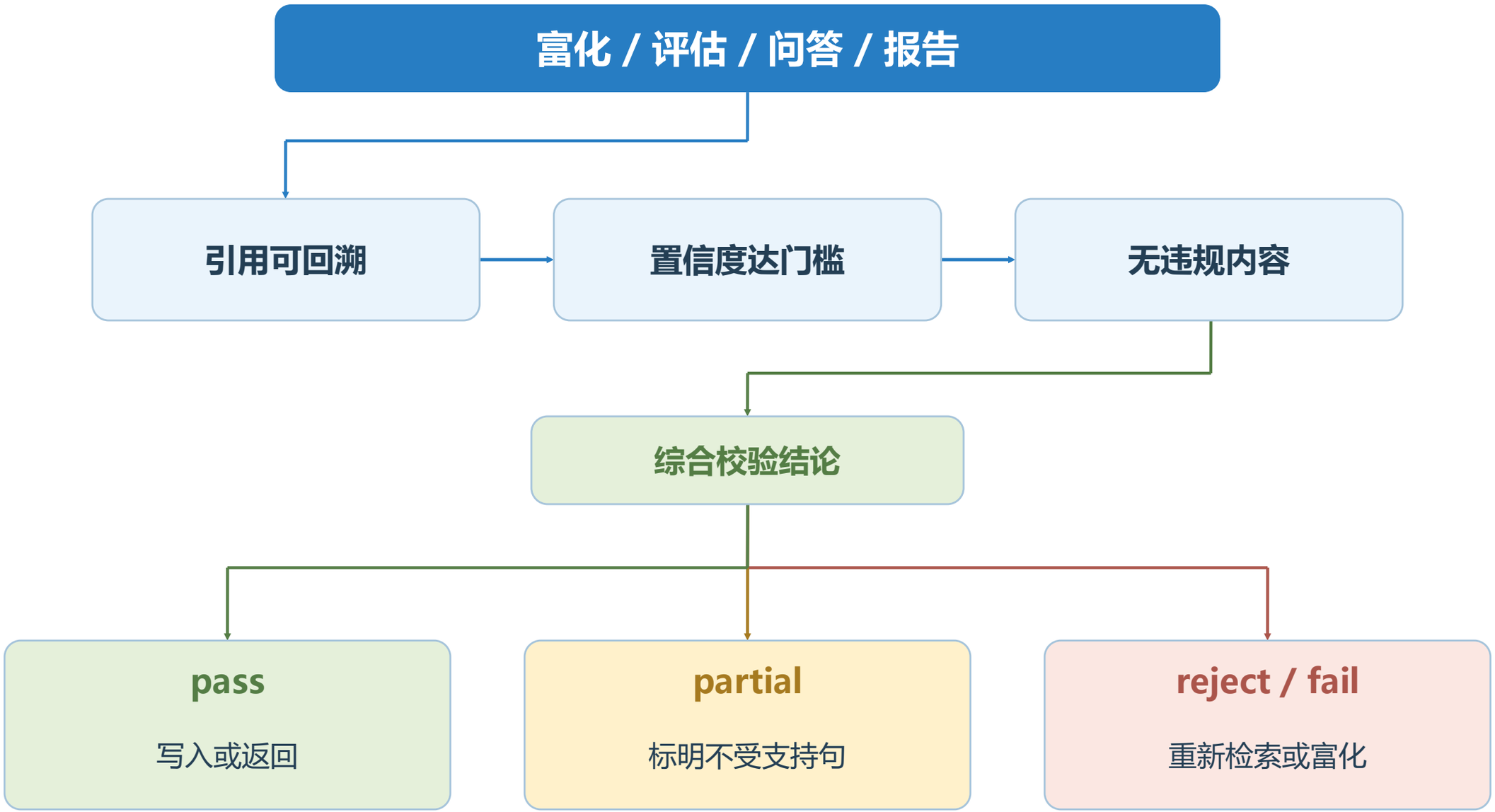
# 任务状态机




retrying 与死信对外均显示为 running

F-08

# Critic 校验闭环




关系边门槛 0.6；问答 partial 比例 ≤30%；LLM 产出 20% 抽检

F-09

# 九类数据源与三级可信度

## 一级 官方

**1.0**

可信度权重

NVD / GHSA reviewed
OSV / KEV / EPSS
ATLAS / 厂商公告
CNNVD / 标准法规
CNVD：人工导入

## 二级 专业平台

**0.7**

可信度权重

huntr / AVID
GHSA unreviewed

测绘平台仅供暴露面
不增加来源类别

## 三级 研究资讯

**0.4**

可信度权重

arXiv
安全博客 RSS

仅三级支撑：unconfirmed
不进入高危告警

平台审核只可下调可信度；CNNVD 主力，CNVD 加分项

F-10

# 各来源采集节奏与目标时延

| 轮询频率 | 来源与触发方式 | 发现时延目标（待测） |
| --- | --- | --- |
| 事件 | 自有仓库 / DEMO | ≤1 min |
| 5 min | P0 厂商公告 | ≤10 min |
| 10 min | GHSA / NVD / RSS | ≤15 / 30 / 30 min |
| 15 min | OSV | ≤30 min |
| 1 h | huntr / KEV | ≤2 h |
| 6 h | AVID | ≤6 h |
| 1 d | EPSS / arXiv / CNNVD | ≤24 h |
| 1 周 | 标准法规 / CNVD | 版本监测 / 人工 |

6 h 口径：NVD、GHSA、OSV、厂商公告、huntr 首次发现；其余单列

F-11

# 去重与合并的三层处理



F-12

# 九维富化画像

**漏洞实体**

1 **CVSS**

NVD / GHSA
保留分歧

2 **EPSS**

FIRST
每日更新

3 **KEV**

仅 KEV 置位

4 **CWE**

来源字段与规则

5 **ATLAS**

规则召回 + LLM

6 **受影响与修复版本**

OSV 区间语义

7 **论文与文章**

嵌入 + 组件共现

8 **PoC 存在性**

仅链接与标题

9 **公网暴露面**

仅聚合计数

蓝色：规则与确定性信息；绿色：弱关联须 Critic 校验；黄色：合规边界

# 暴露面计数的语法校准

## Quake 暴露面口径收窄

**823 690**

宽口径，仅作上限参考

↓

**172 411**

收窄全球：端口 + 响应特征

↓

**51 612**

国内：按平台国家字段

计数时间 15:57

### 元数据抽样验证

**44 / 50**

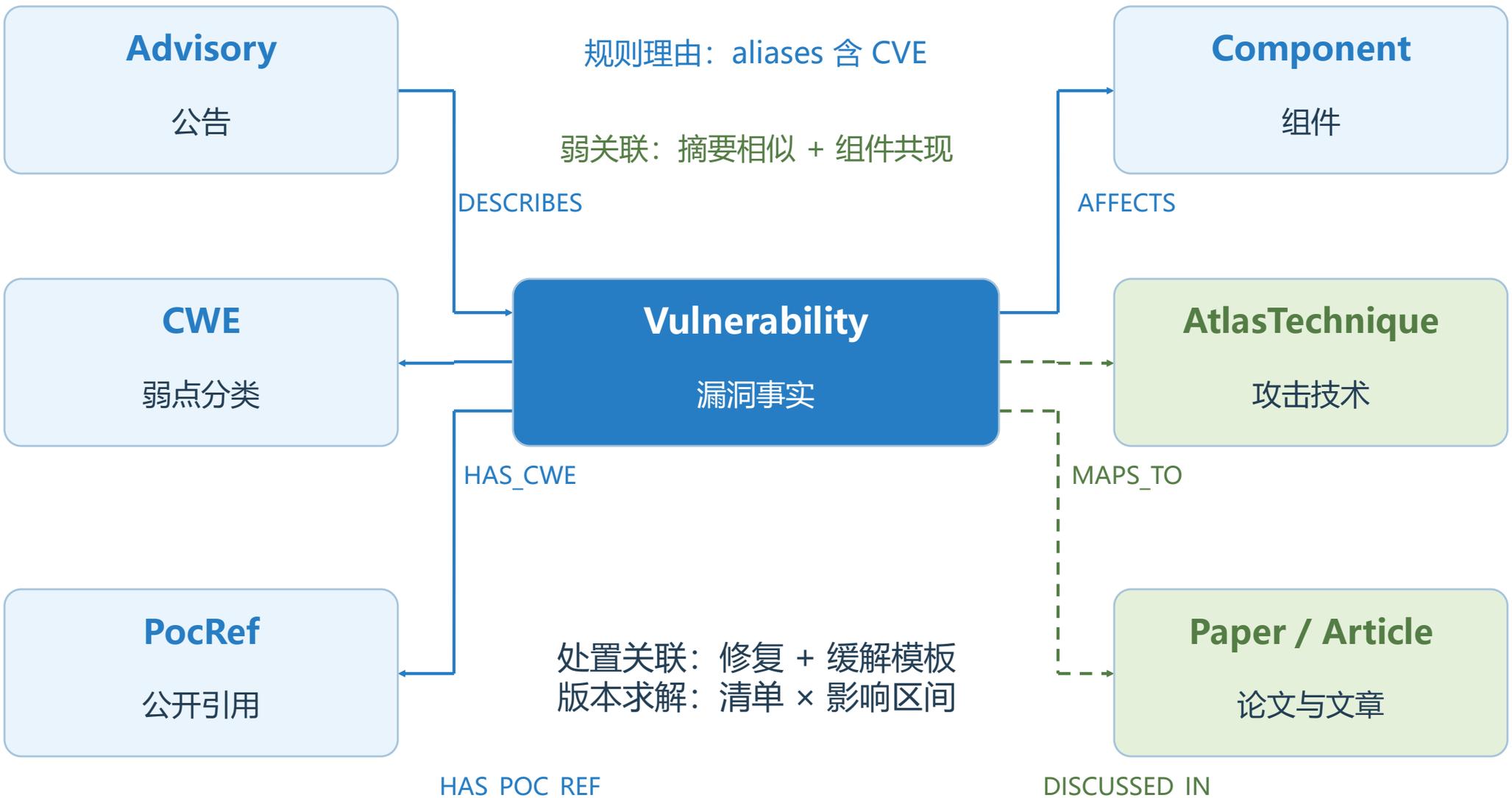
**精确率 88% ≥80%**
**verified**

抽样时间 19:55
当时总数 172 401

2026-10-15，仅计数；Talos / Shodan 文献为 1139，覆盖口径不同，不直接比较

F-14

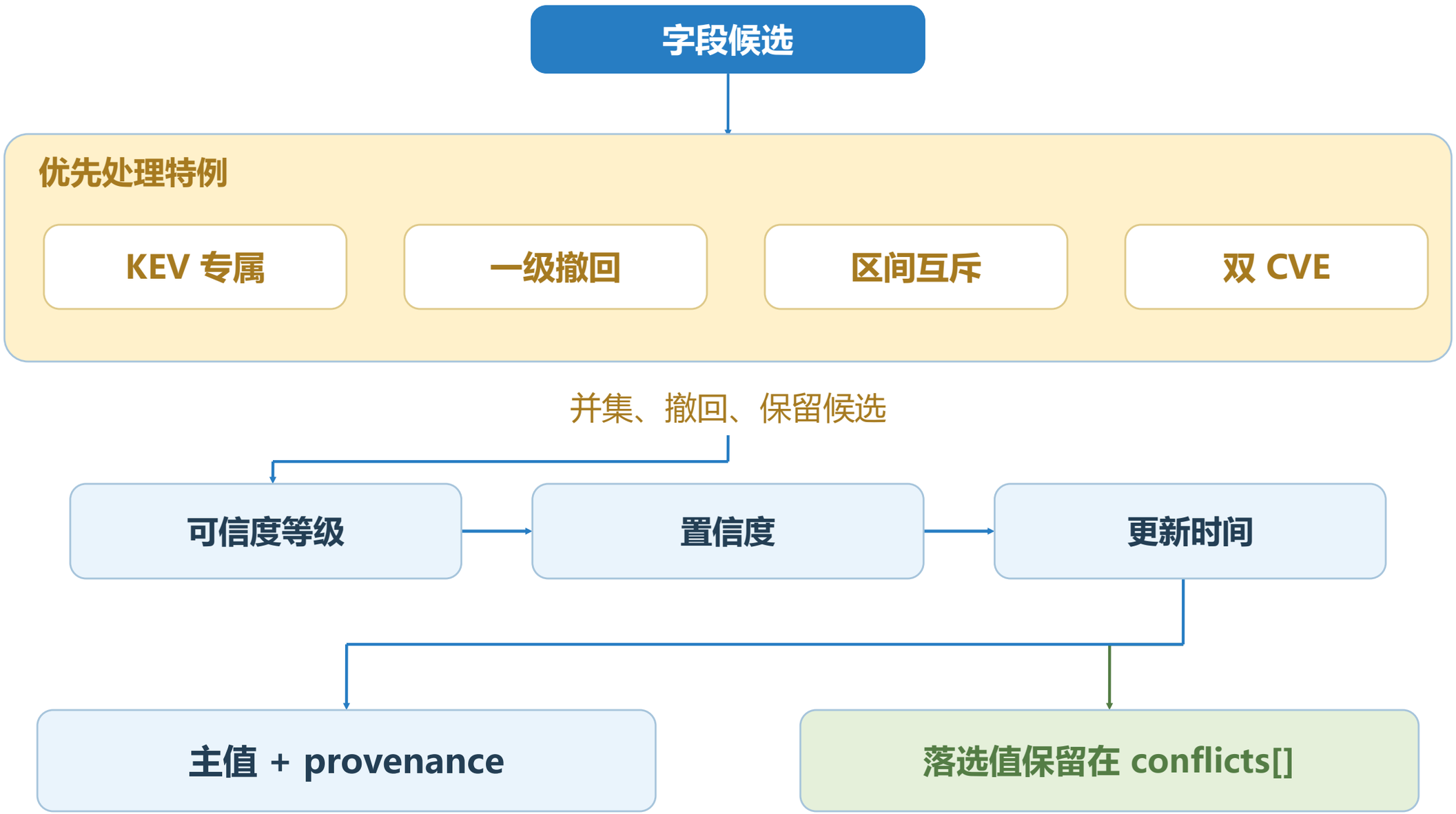
# 六类自动关联




实线表示确定性关联；虚线表示须经 Critic 校验的弱关联

F-15

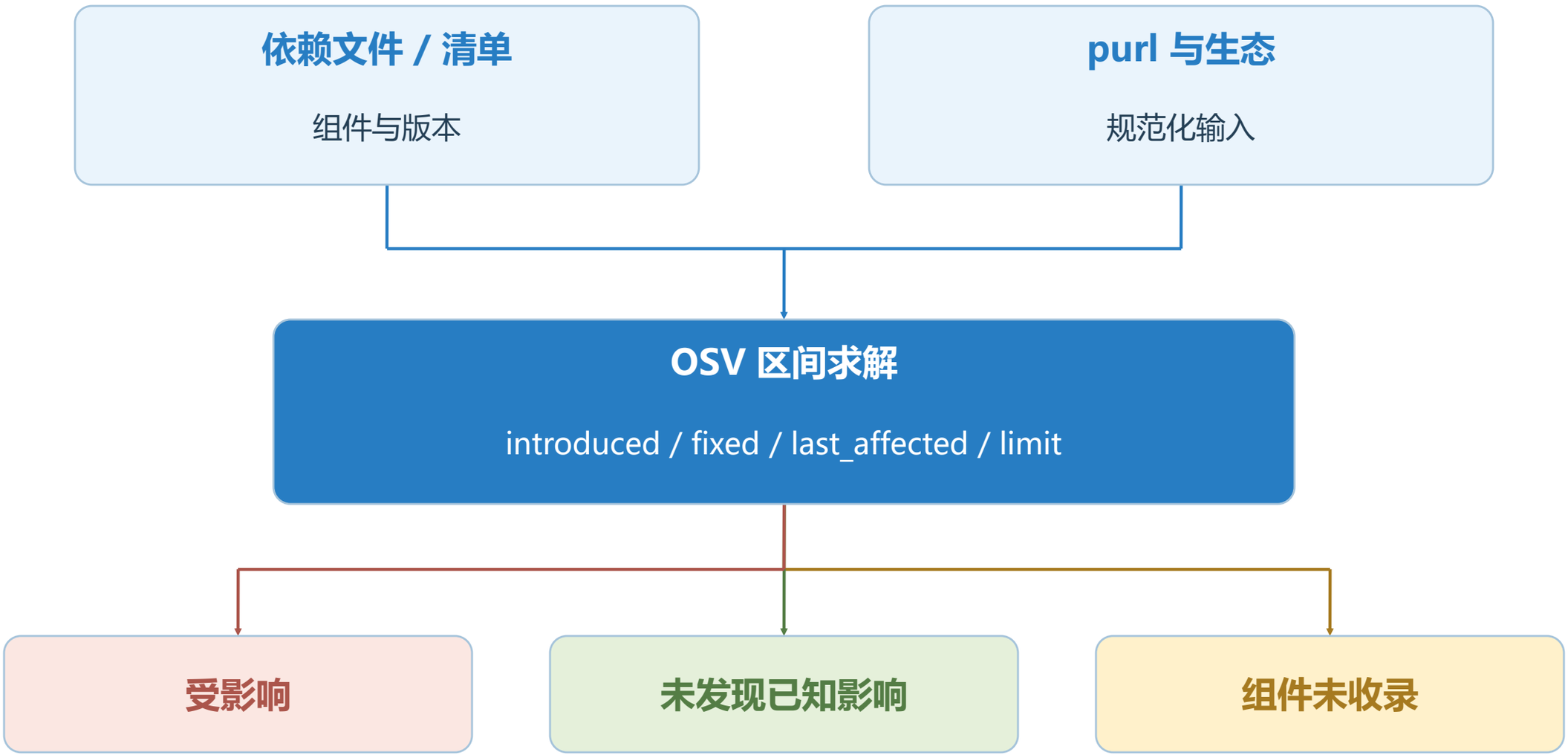
# 多源冲突的逐字段裁决




CVSS 10.0 与 9.8 均保留；主值选择不抹去分歧

F-16

# 版本自查流程

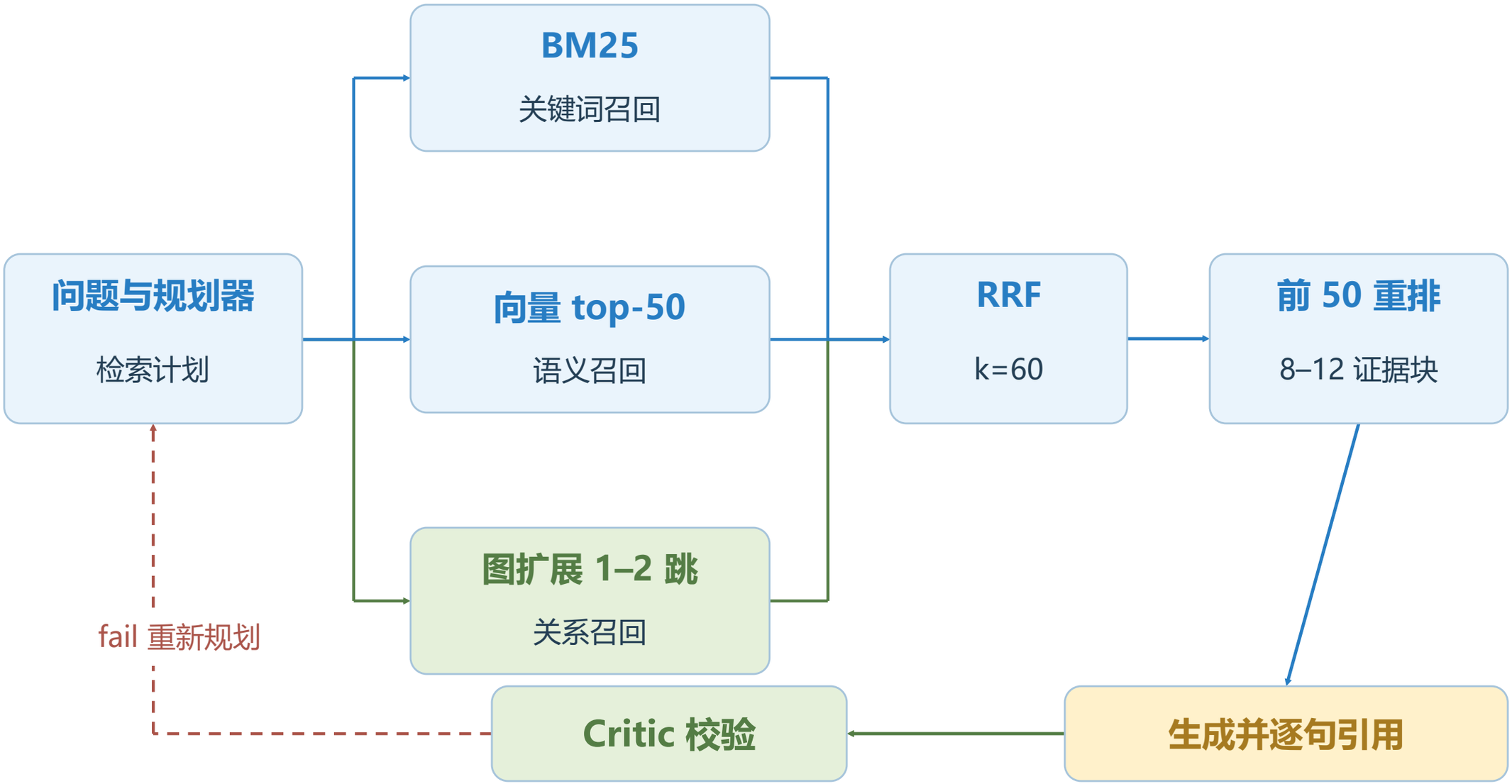



**共享入口：Web / check_stack / shaowang check**

区间有分歧时提示；高危退出码 1 可接 CI；未知不等于安全

F-17

# 三路混合检索与 GraphRAG 问答流程

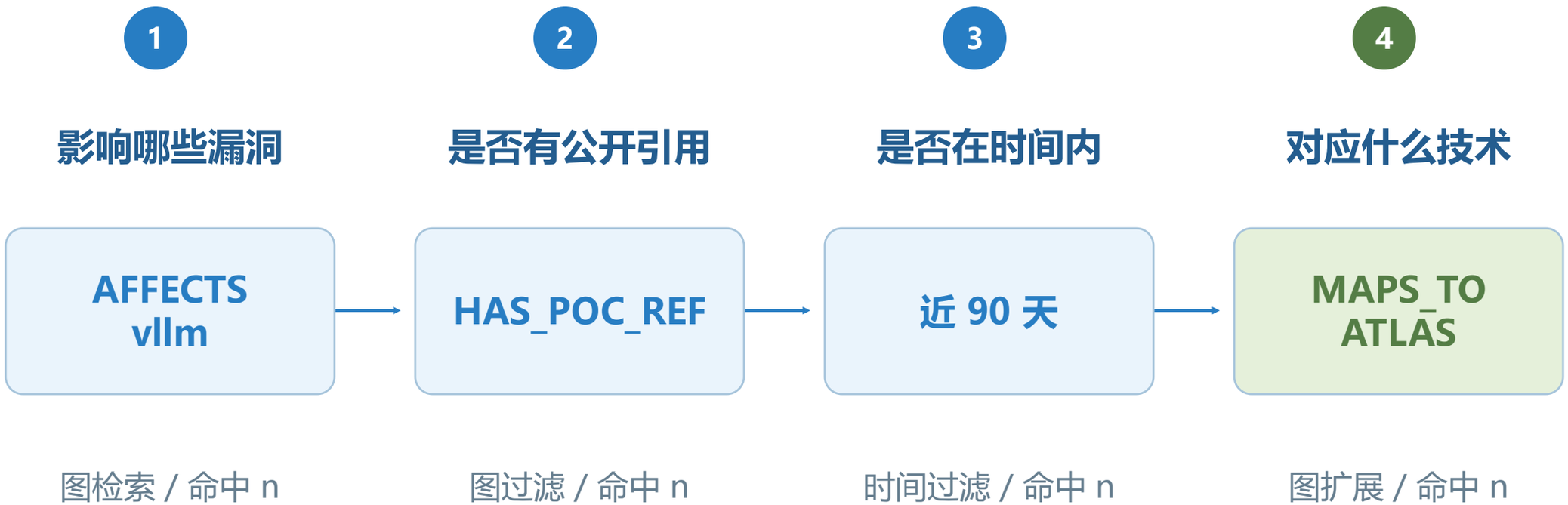



三路排名融合，不混加原始分数；校验通过后返回答案

F-18

# 多跳问答的推理链示例

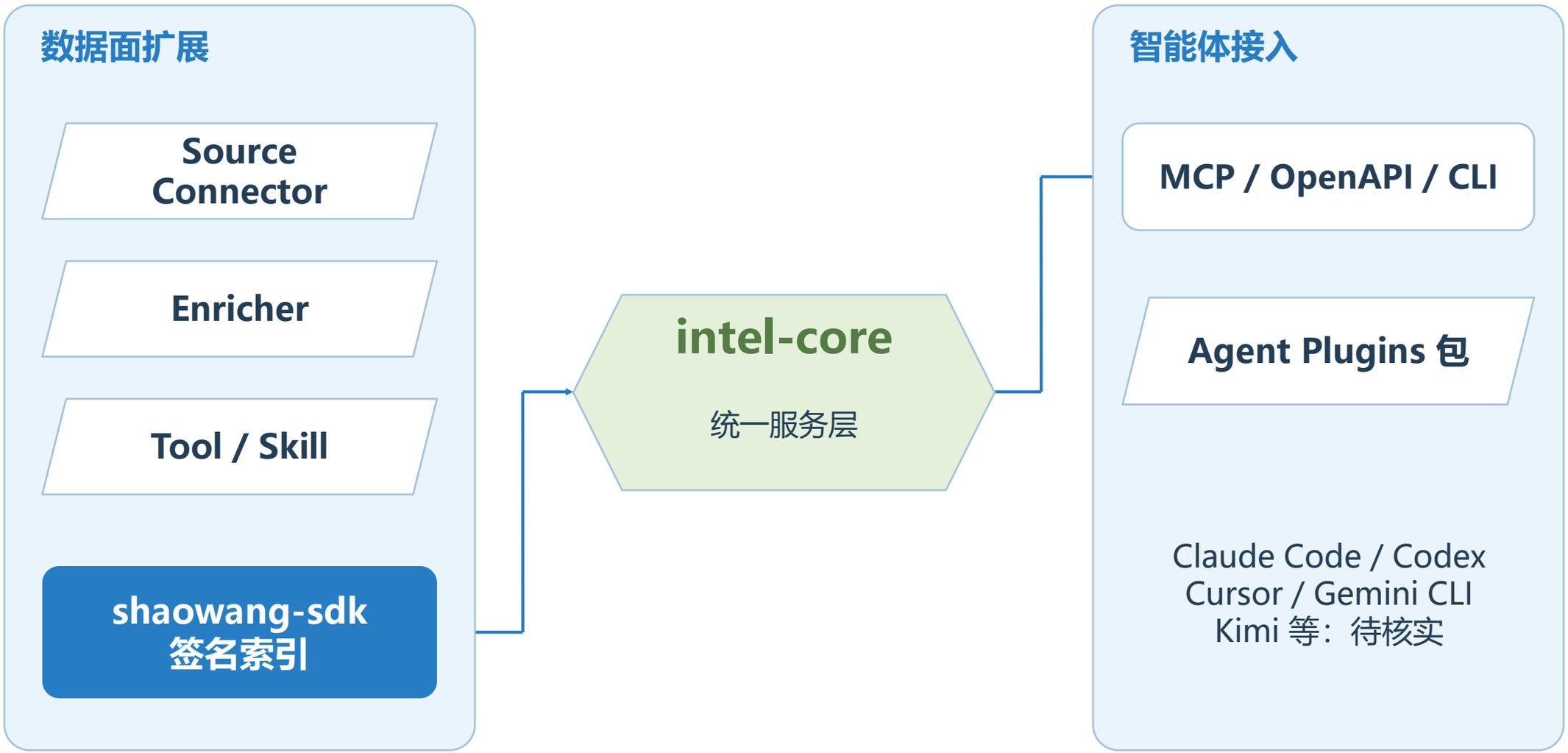
**近 90 天影响 vLLM 且有公开 PoC 链接的漏洞及其 ATLAS 技术**




reasoning_steps 保存子问题、检索方式、查询语句与命中数；n 是示意占位，非实测

F-19

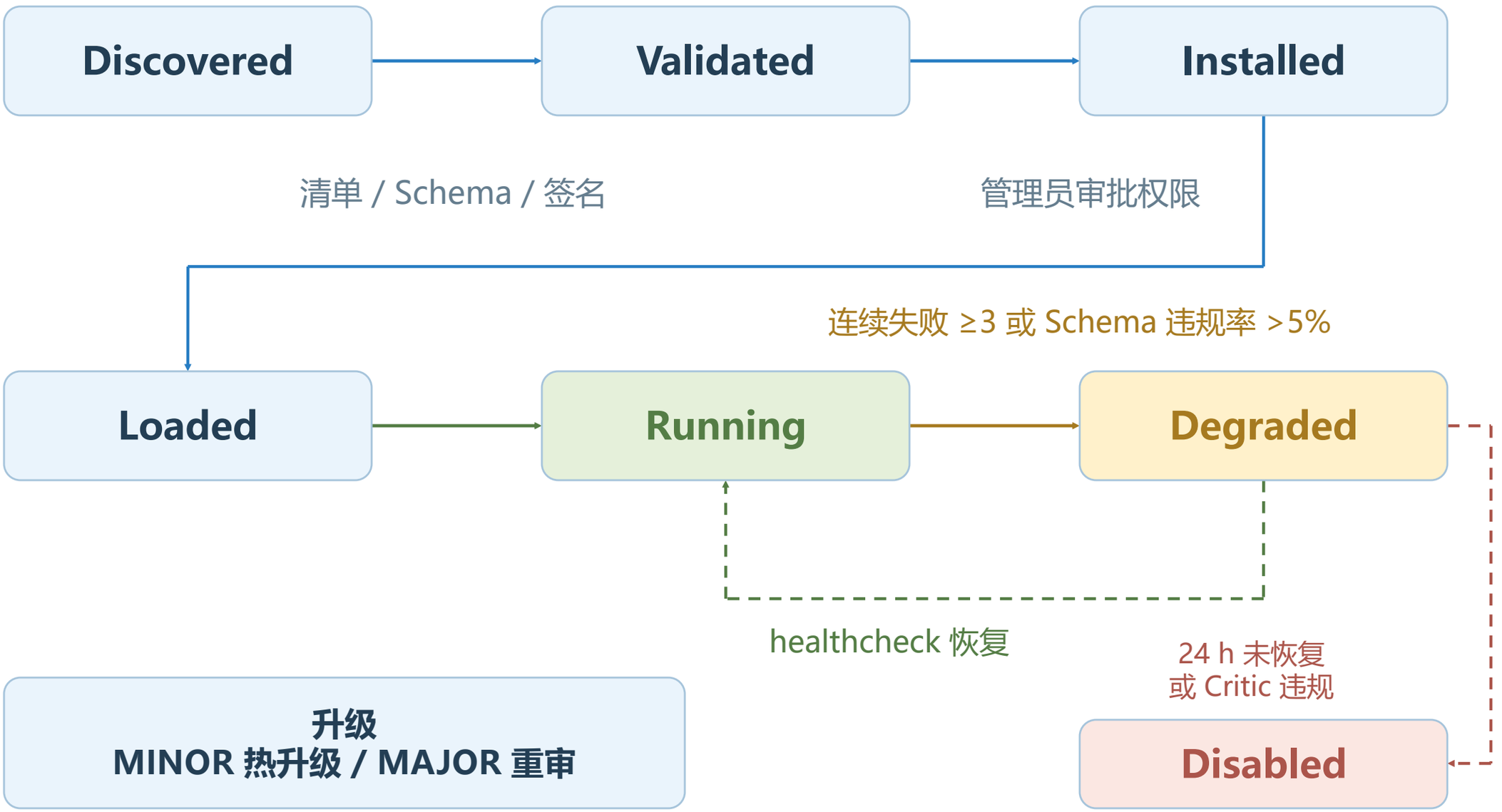
# MCP 与插件生态全景




统一鉴权、限流、审计与长任务句柄

F-20

# 插件生命周期


Discovered
Validated
Installed
清单 / Schema / 签名
管理员审批权限
连续失败 ≥3 或 Schema 违规率 >5%
Loaded
Running
Degraded
healthcheck 恢复
24 h 未恢复
或 Critic 违规
Disabled
升级
MINOR 热升级 / MAJOR 重审

F-21

# 公开 Schema 与 OSV / STIX 2.1 / CSAF 2.0 的对应

## 8 类公开 Schema

| | | | |
|---|---|---|---|
| **common** | **normalized-intel** | **vulnerability** | **advisory** |
| **component** | **enrichment** | **relation** | **qa-answer** |

| 映射对象 | OSV | STIX 2.1 | CSAF 2.0 |
|---|---|---|---|
| 标识 / 别名 | id / aliases | external_references | cve / ids |
| 影响区间 | ranges.events | software + relation | product_status |
| 处置建议 | FIX 引用 | course-of-action | remediations |
| ATLAS | 无原生项 | attack-pattern | notes |
| 关系与置信度 | 无原生项 | relationship | 无原生项 |
| PoC 引用 | EVIDENCE 链接 | external_references | references |

按映射表保留语义；没有原生字段的内容使用扩展，不能宣称天然无损

F-22

# 技术栈分层

| 层次 | 报告方案 | 备选 |
| --- | --- | --- |
| 采集 | Python / httpx（建议） | requests / Scrapy |
| 消息调度 | Redis Streams / NATS | Kafka |
| 编排 | LangGraph | AutoGen / CrewAI |
| 模型 | Qwen / DeepSeek（建议） | 私有化模型 |
| 主存储 | PostgreSQL + pgvector | Milvus |
| 图谱与检索 | Neo4j / OpenSearch + IK | AGE / Meilisearch |
| 嵌入与重排 | bge-m3 / bge-reranker | 商用嵌入 |
| 后端与 MCP | FastAPI / 官方 Python SDK | Litestar / FastMCP |
| 前端 | React / ECharts / Cytoscape | Vue / AntV G6 |
| 可观测 | Langfuse / Prometheus / Grafana | OpenTelemetry 后端 |
| 部署 | docker compose | Kubernetes / Helm |

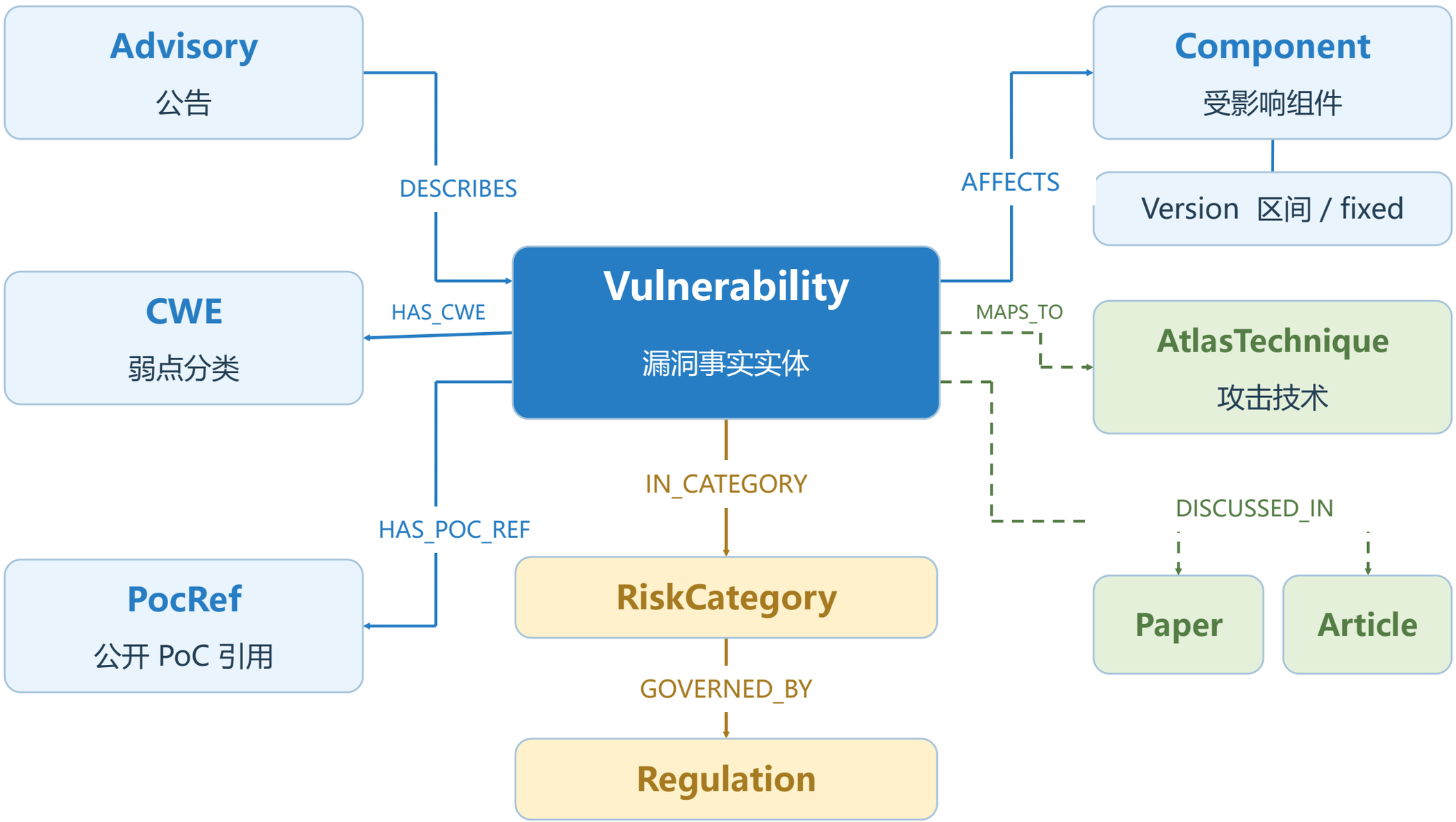
右列为备选；建议项与规划项不等于已经部署

F-23

# docker compose 单机部署结构



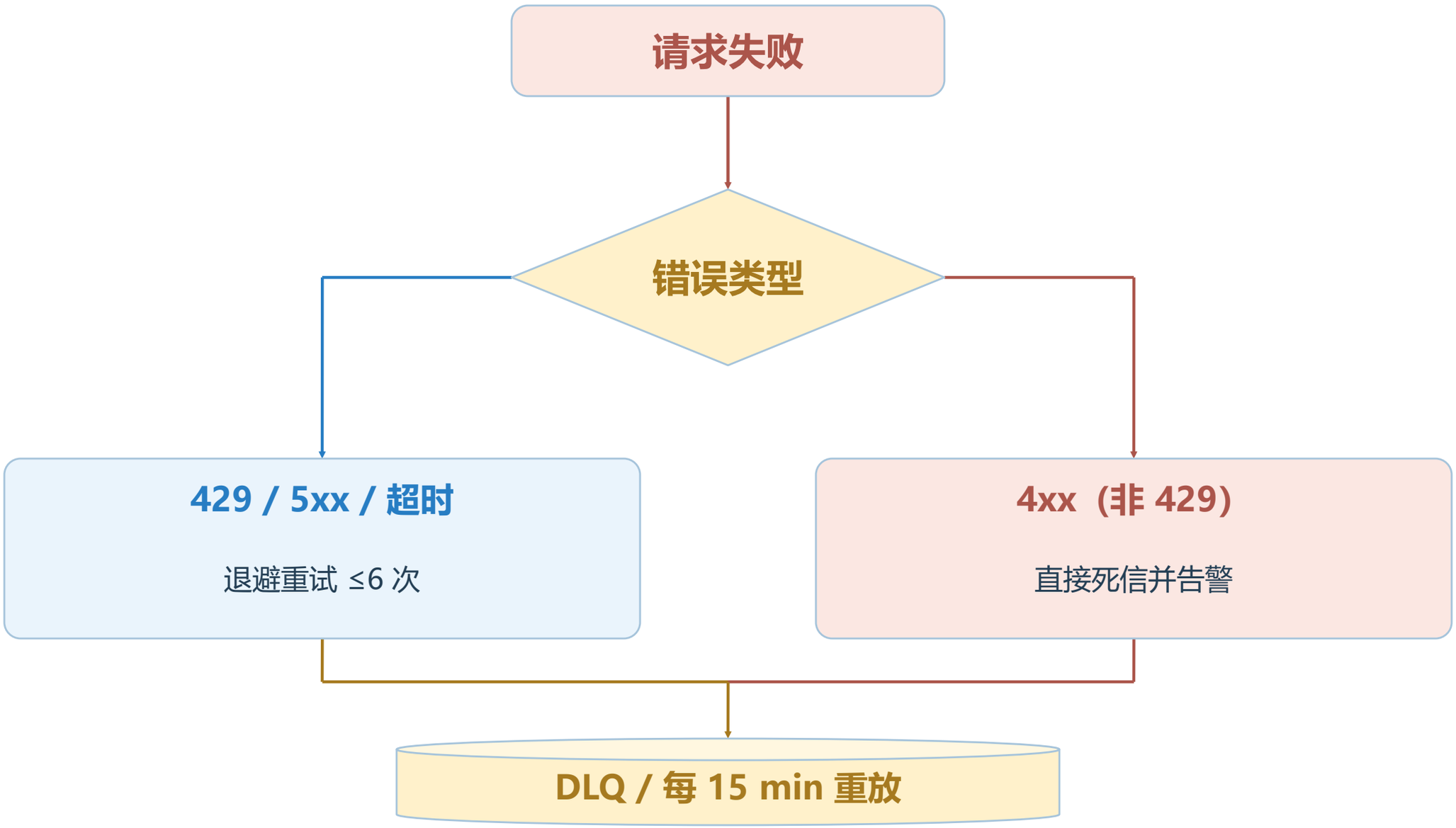
# 知识图谱数据模型




边属性：reason / confidence / method / created_by_agent

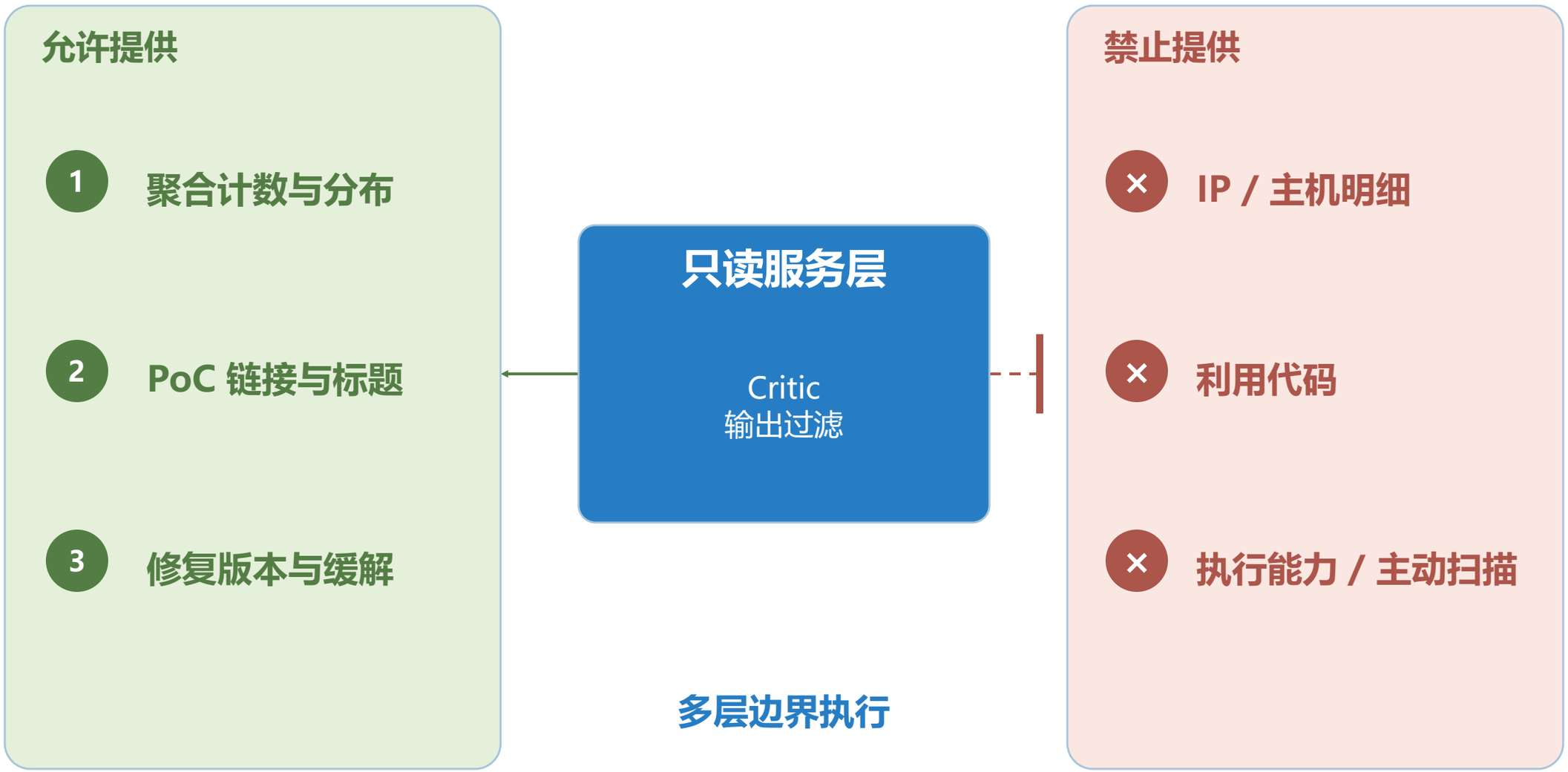
F-25

# 失败重试、死信重放与熔断降级




Retry-After 优先；否则 1 s 起 ×2，上限 5 min，±20% 抖动；连续 3 周期失败后降级

# 对外合规边界




合规限制在采集、存储、服务与校验多个边界执行

F-27

# 时效统计的时间戳定义




**采集时延**
**首见 − 发布**

**处理时延**
**可查询 − 首见**

**端到端 = 可查询 − 发布**
**目标值 ≤6 h（待测）**

仅漏洞类首次发现；日更源单列；DEMO 不计；日期精度不足按当日零点计，保守高估

F-29

# 七项创新点总览

| | 创新方向 | 关键机制 | 验证维度 |
|---|---|---|---|
| 1 | 面向 AI 基础设施的垂直多源融合 | P0 5 min / 无 CVE 入库 | 监测 / 时效 |
| 2 | 可解释的自动关联推理引擎 | 边带理由 / Critic 门槛 | 富化 / 准确 |
| 3 | 从依赖文件出发的影响自查 | OSV 求解 / 三种结果 | 富化 / Agent |
| 4 | 可解释 GraphRAG 问答 | 三路检索 / 逐句引用 | 问答 / 准确 |
| 5 | 内部多智能体编排与外部 MCP 开放 | 9 角色 / 统一服务层 | Agent |
| 6 | 时效可观测与故障自愈 | 五段时间戳 / 故障恢复 | 时效 / 自动化 |
| 7 | 开放的插件生态 | 8 Schema / 三类扩展点 | Agent / 文档 |

七项创新均需第四章评测验证；当前未测结果保持占位

# 评测体系总览

| | 时效 | 富化 | 问答 | 自愈 | 兼容 |
|---|---|---|---|---|---|
| 输入 | 五段时间戳 | 200 条金标 | 约 100 题 | 6 个场景 | 4 类客户端 |
| 对照 / 方法 | 按源分项 | Critic 前后 | 三组对照 | 故障注入 | 远程 / stdio |
| 观测指标 | P50 / P95 | 准确率 / κ | 答案 / 引用 | 成功率 / 恢复 | 加载 / 续取 |
| 验收目标 | 目标值 ≤6 h（待测） | 目标值 ≥95%（待测） | 目标值待定（待测） | 目标值待定（待测） | 目标值待定（待测） |

同模型同提示；保存原始结果；未执行不计为通过